Cryptography Unit I: Introduction to Cryptography (Detailed Notes)

Syllabus: Introduction to cryptography, security threats, vulnerability, active and passive attacks, security services and mechanisms, prevention, detection, deterrence, malicious code, conventional encryption model, CIA model. Primary text: Atul Kahate, Cryptography and Network Security. These notes follow the OSI Security Architecture (ITU-T X.800), which most Indian university syllabi and Stallings-style textbooks use as the framework for this unit.

1. Introduction to Cryptography

1.1 What cryptography is

Cryptography is the science of protecting information by transforming it into a form that only the intended parties can understand. The word comes from the Greek for "hidden writing". Today it covers much more than secrecy: it is also used to prove who sent a message, to prove that a message was not changed, and to prevent a sender from denying a message later.

1.2 Terminology

Term	Meaning
Plaintext	The original, readable message or data.
Ciphertext	The scrambled output of encryption, unreadable without the key.
Encryption (enciphering)	Converting plaintext to ciphertext using an algorithm and a key.
Decryption (deciphering)	Recovering plaintext from ciphertext using the algorithm and the key.
Cipher	The algorithm used for encryption and decryption.
Key	The secret value that controls the transformation. The set of all possible keys is the key space.
Cryptography	Designing and studying methods of securing information.
Cryptanalysis	Studying ways to recover plaintext or keys without being given the key.

Term	Meaning
Cryptology	Cryptography and cryptanalysis together.
Cryptosystem	The complete scheme: plaintext space, ciphertext space, key space, and the encryption and decryption rules.

1.3 Main families of cryptographic algorithms

- **Symmetric-key (conventional) algorithms** use one shared secret key for both encryption and decryption (DES, AES). They are fast and suit bulk data.
- **Asymmetric-key (public-key) algorithms** use a key pair: a public key to encrypt or verify and a private key to decrypt or sign (RSA, ElGamal). They solve key distribution but are slower. They are covered in Unit IV.
- **Hash functions** take a message of any length and produce a fixed-length digest, with no key (SHA, MD5). They support integrity checking and are covered in Unit V.

1.4 Why cryptography is needed

Networks are open to anyone who can reach a link or a router. Data sent over such a network can be read, copied, changed or replayed unless it is protected. Cryptography supplies the building blocks for confidentiality, authentication, integrity and non-repudiation. Typical uses are HTTPS, online banking, email security, VPNs, software updates and digital payments.

2. Basic Security Concepts

- **Computer security**: the collection of tools designed to protect data on a computer system and to thwart intruders.
- **Network security**: measures to protect data during transmission across a network.
- **Internet security**: measures to protect data during transmission over a collection of interconnected networks.
- **Information security** is the broader term covering all of the above, together with people and procedures.

2.1 OSI Security Architecture (ITU-T X.800)

X.800 defines a systematic way of organizing the task of providing security. It focuses on three ideas:

1. **Security attack**: any action that compromises the security of information owned by an organization or person.
2. **Security mechanism**: a process or device designed to detect, prevent or recover from a security attack.
3. **Security service**: a processing or communication service that enhances the security of data processing systems and information transfers. A service is intended to counter attacks and uses one or more mechanisms to do so.

The relationship is: attacks are countered by services, and services are implemented by mechanisms. A service often mimics something familiar from the paper world, for example a

signature, a witnessed document or a sealed envelope.

3. Vulnerability, Threat and Attack

Term	Definition	Example
Vulnerability	A weakness in design, implementation, configuration or procedure that could be exploited.	Default administrator password, unpatched server, no input validation.
Threat	A potential circumstance, entity or event that could exploit a vulnerability and cause harm.	An attacker on the internet, a disgruntled employee, a flood.
Attack	A deliberate attempt to exploit a vulnerability to evade security services and violate policy.	SQL injection, packet sniffing, phishing.
Risk	The likelihood that a threat exploits a vulnerability, combined with the impact if it does.	High likelihood of ransomware on an unpatched file server.
Countermeasure	An action, device or procedure that reduces a vulnerability or the effect of an attack.	Patching, firewall, encryption, training.

3.1 Four categories of threat to information flow

Consider information flowing from a source to a destination.

1. **Interruption**: the flow is stopped or an asset is destroyed or made unavailable. This attacks availability. Examples: cutting a cable, deleting files, flooding a server.
2. **Interception**: an unauthorized party gains access to an asset. This attacks confidentiality. Examples: wiretapping, sniffing packets, copying files.
3. **Modification**: an unauthorized party gains access and also tampers with the asset. This attacks integrity. Examples: changing values in a database, altering a message in transit.
4. **Fabrication**: an unauthorized party inserts counterfeit objects. This attacks authenticity. Examples: forged messages, fake records, spoofed login pages.

4. Passive and Active Attacks

X.800 and RFC 4949 classify attacks into two groups according to whether the attacker changes anything.

4.1 Passive attacks

The attacker only observes or records. Nothing in the system is altered, so these attacks are very hard to detect. The defense is therefore prevention, mainly encryption.

- **Release of message contents**: reading a telephone call, an email or a transferred file. Encryption makes the content unintelligible.
- **Traffic analysis**: even when content is encrypted, the attacker watches the pattern, meaning source and destination, frequency, length and timing of messages, and draws conclusions. Countermeasures include traffic padding and routing control.

4.2 Active attacks

The attacker modifies the data stream or creates a false one. They are easy to detect in principle but hard to prevent completely, because that would need protection of every communication facility at all times. The goal is therefore to detect them and recover from any disruption.

- **Masquerade**: one entity pretends to be another. It often accompanies another active attack, for example capturing an authentication sequence and replaying it to gain extra privileges.
- **Replay**: a data unit is passively captured and later retransmitted to produce an unauthorized effect, such as repeating a bank transfer.
- **Modification of messages**: part of a legitimate message is altered, delayed or reordered. Example: changing "Allow John to read the confidential file" to "Allow Fred to read the confidential file".
- **Denial of service (DoS)**: the normal use or management of communication facilities is prevented or inhibited, for example by flooding a server with requests or by suppressing messages to a destination.

4.3 Comparison

Point	Passive attack	Active attack
Nature	Eavesdropping or monitoring	Alteration, creation or disruption
Effect on system	None; data unchanged	Data or services changed
Property attacked	Confidentiality	Integrity, availability, authenticity
Detection	Very difficult	Possible
Prevention	Practical (encryption)	Difficult to prevent in full
Main emphasis	Prevention	Detection and recovery
Examples	Sniffing, traffic analysis	Masquerade, replay, modification, DoS

4.4 Other attack terms worth knowing

- **Man-in-the-middle attack**: the attacker sits between two parties, relays and possibly changes their messages while each believes they talk directly. It combines interception and masquerade.
- **Insider and outsider attacks**: an inside attack is launched by someone within the security perimeter, an outside attack from beyond it.
- **Cryptanalytic attacks** on ciphers (ciphertext-only, known-plaintext, chosen-plaintext, chosen-ciphertext) are covered in Section 9 and again in Unit III.

5. Security Services (X.800)

X.800 defines a security service as a service provided by a protocol layer of communicating open systems that ensures adequate security of the systems or of data transfers. It divides services into five categories containing fourteen specific services.

Category	Specific services	Meaning
Authentication	Peer entity authentication; data origin authentication	Confirms that the communicating party is who it claims to be. Peer entity authentication is used during a connection. Data origin authentication confirms the source of a single data unit and gives no protection against duplication or replay.
Access control	One service	Prevents unauthorized use of a resource: who may access it, under what conditions, and what they may do.
Data confidentiality	Connection confidentiality; connectionless confidentiality; selective-field confidentiality; traffic-flow confidentiality	Protects data from unauthorized disclosure. Selective-field protects only chosen fields of a message. Traffic-flow protects against traffic analysis.
Data integrity	Connection integrity with recovery; connection integrity without recovery; selective-field connection integrity; connectionless integrity; selective-field connectionless integrity	Ensures data is received exactly as sent, with no insertion, modification, deletion or replay. With recovery means the system also tries to restore the data.
Non-repudiation	Origin; destination	Prevents the sender from

Category	Specific services	Meaning
		denying sending a message and the receiver from denying receiving it.

Availability is treated by X.800 as a property that other services (such as access control) help to deliver. It is the ability of a system to be accessible and usable on demand by an authorized entity. Many textbooks list it as a sixth service.

6. Security Mechanisms (X.800)

Mechanisms implement services. X.800 separates those built into a specific protocol layer from those that apply across the whole system.

6.1 Specific security mechanisms

1. **Encipherment**: using mathematical algorithms to make data unreadable. Can be reversible (normal encryption) or irreversible (hashes and MACs).
2. **Digital signature**: data appended to, or a transformation of, a data unit that lets the recipient verify the source and integrity and protects against forgery.
3. **Access control**: mechanisms that enforce access rights to resources, such as passwords, tokens and permission lists.
4. **Data integrity**: mechanisms that verify the integrity of a data unit or stream, such as checksums, hashes and MACs.
5. **Authentication exchange**: a protocol exchange that proves identity, for example a challenge-response handshake.
6. **Traffic padding**: inserting bits into gaps of a data stream to frustrate traffic analysis.
7. **Routing control**: selecting secure routes for certain data and changing routes when a breach is suspected.
8. **Notarization**: using a trusted third party to assure properties of a data exchange, such as time, origin or content.

6.2 Pervasive security mechanisms

1. **Trusted functionality**: functionality that is considered correct with respect to some criteria, for example one set by a security policy.
2. **Security label**: a marking bound to a resource that names its security attributes, such as a classification level.
3. **Event detection**: detecting security-relevant events, including violations and normal events such as a successful login.
4. **Security audit trail**: a record of system activity that allows later independent review of records and detection of breaches.
5. **Security recovery**: dealing with requests from mechanisms such as event handling and management functions, and taking recovery actions.

6.3 Which mechanism supports which service

Service	Encipherment	Digital signature	Access control	Data integrity	Authentication exchange	Traffic padding	Routing control	Notarization
Peer entity authentication	Yes	Yes			Yes			
Data origin authentication	Yes	Yes						
Access control			Yes					
Confidentiality	Yes						Yes	
Traffic-flow confidentiality	Yes					Yes	Yes	
Data integrity	Yes	Yes		Yes				
Non-repudiation		Yes		Yes				Yes
Availability				Yes	Yes			

7. Prevention, Detection, Deterrence and Recovery

A sound security program combines several kinds of control, because no single one is sufficient. This layering is called defense in depth.

Control type	Purpose	Examples
Prevention	Stop the attack from succeeding.	Encryption, firewalls, strong authentication, access control, patching, input validation, physical locks.
Detection	Discover that an attack is happening or has happened.	Intrusion detection systems, log monitoring, integrity checkers, antivirus scans,

Control type	Purpose	Examples
		audits, CCTV.
Deterrence	Discourage attackers from trying in the first place.	Laws and penalties, warning banners, visible monitoring, security policies with disciplinary action, publicized prosecution.
Recovery (response)	Restore normal operation and limit damage.	Backups, disaster recovery plans, incident response teams, forensic analysis, system rebuild.

- Prevention is preferred for passive attacks, where detection is impractical.
- Detection and recovery matter most for active attacks.
- Deterrence works on the attacker's decision, not on the system. It relies on a credible chance of being caught and punished.

8. Malicious Code

Malicious code (malware) is software written to harm a system, steal data or give an attacker control. It is classified by how it spreads and what it does. Two broad groups: programs that need a host program (viruses, logic bombs, trapdoors) and independent programs (worms, zombies, bots).

8.1 Types

Type	Description
Virus	Attaches itself to a host program or file and replicates when the host runs. It needs a user action or a host execution to spread.
Worm	A standalone program that replicates itself and spreads across networks by exploiting vulnerabilities or through email, without needing a host file.
Trojan horse	Appears to be a useful program but contains hidden malicious functionality. It does not replicate by itself.
Logic bomb	Code that stays dormant until a condition is met (a date, a missing record, a user action) and then executes a harmful payload.
Trapdoor (backdoor)	A secret entry point that bypasses normal

Type	Description
	authentication. Programmers sometimes leave it for testing and it later becomes a weakness.
Spyware and keylogger	Secretly collects user information, including keystrokes, browsing and credentials, and sends it to an attacker.
Adware	Displays unwanted advertising, often bundled with free software.
Ransomware	Encrypts the victim's files and demands payment for the decryption key.
Rootkit	A set of tools that gives an attacker privileged access while hiding its own presence and the presence of other malware.
Zombie (bot)	A compromised machine under remote control. A network of bots is a botnet, used for DDoS attacks, spam and fraud.

8.2 Phases of a virus

1. **Dormant phase**: the virus is idle, waiting for a trigger such as a date or a program launch.
2. **Propagation phase**: it copies itself into other programs or system areas.
3. **Triggering phase**: a condition activates it.
4. **Execution phase**: the payload runs, which may be harmless or destructive.

8.3 Kinds of virus by behavior

- **Parasitic**: attaches to executable files.
- **Memory-resident**: loads into main memory and infects every program that runs.
- **Boot sector**: infects the master boot record and spreads when the system boots.
- **Stealth**: designed to hide from antivirus software.
- **Polymorphic**: changes its signature on each infection by mutating its encrypted body.
- **Metamorphic**: rewrites its own code on each infection, so it looks different in behavior and appearance.
- **Macro**: written in the macro language of office applications and carried in documents.

8.4 Countermeasures

- Prevention: regular patching, least-privilege accounts, avoiding untrusted attachments and downloads, application whitelisting, network segmentation.
- Detection: antivirus based on signatures, heuristics and behavior monitoring; integrity checkers; sandboxing.
- Identification and removal: isolate the host, identify the strain, clean or restore from a

known-good backup.
- Backups kept offline are the main defense against ransomware.

9. Conventional (Symmetric) Encryption Model

9.1 Components

1. **Plaintext** X: the original message, the input to the algorithm.
2. **Encryption algorithm**: performs substitutions and transformations on the plaintext.
3. **Secret key** K: independent of the plaintext and of the algorithm. The exact substitutions and transformations depend on it.
4. **Ciphertext** Y: the scrambled output, which depends on the plaintext and the key. Different keys give different ciphertexts for the same plaintext.
5. **Decryption algorithm**: the encryption algorithm run in reverse, taking the ciphertext and the same key to give back the plaintext.

Formally: Y = E(K, X) and X = D(K, Y). The sender and receiver share K, and an opponent can see Y but not K. If the opponent knows Y but not X or K, they try to recover X, K or both.

9.2 Two requirements for secure use

1. A strong encryption algorithm. Even if the opponent knows the algorithm and has a number of ciphertexts and their plaintexts, the key must not be recoverable.
2. A secure way to distribute and store the key. Anyone who gets the key can read all traffic encrypted with it. This is the key distribution problem, treated in Unit II.

9.3 Kerckhoffs's principle

The security of a cryptosystem should depend only on the secrecy of the key, not on the secrecy of the algorithm. Algorithms can be leaked, reverse engineered or published for public review. This is why standards such as AES are open.

9.4 Ways to attack a conventional cipher

- **Cryptanalysis** exploits the characteristics of the algorithm, plus some knowledge of the plaintext or some plaintext-ciphertext pairs, to deduce the plaintext or the key.
- **Brute-force attack** tries every possible key until readable plaintext appears. On average half the key space must be tried.

Attack type	What the cryptanalyst has
Ciphertext only	The encryption algorithm and the ciphertext.
Known plaintext	As above, plus one or more plaintext-ciphertext pairs made with the secret key.
Chosen plaintext	As above, plus plaintext chosen by the attacker and its ciphertext under the secret

Attack type	What the cryptanalyst has
	key.
Chosen ciphertext	As above, plus ciphertext chosen by the attacker and its decryption under the secret key.
Chosen text	Both chosen plaintext and chosen ciphertext.

9.5 Brute-force time for different key sizes

Assuming one decryption per microsecond and an average of half the keys tried:

Key size (bits)	Number of keys	Average time
32	2^{32} (about 4.3×10^{9})	About 36 minutes
56 (DES)	2^{56} (about 7.2×10^{16})	About 1,142 years
128 (AES)	2^{128} (about 3.4×10^{38})	About 5.4×10^{24} years

With massively parallel hardware these times fall by factors of millions, which is why 56-bit DES is no longer safe but 128-bit AES remains out of reach.

9.6 Unconditional and computational security

- **Unconditionally secure**: the ciphertext gives no information to determine the plaintext, however much computing power is used. Only the one-time pad has been proved to meet this.
- **Computationally secure**: the cost of breaking exceeds the value of the information, or the time required exceeds its useful lifetime. All practical ciphers aim for this.

10. CIA Model

The CIA triad (confidentiality, integrity, availability) states the three core objectives of information security. Its opposite is sometimes called the DAD triad: disclosure, alteration, destruction (denial).

Objective	Meaning	Failure	Typical controls
Confidentiality	Information is accessible only to authorized parties. Includes privacy.	Unauthorized disclosure	Encryption, access control, authentication, data classification
Integrity	Information and systems are modified only by authorized parties and in authorized ways.	Unauthorized modification or destruction	Hashes, MACs, digital signatures, version control, input validation

Objective	Meaning	Failure	Typical controls
	Includes data integrity and system integrity.		
Availability	Systems and data are accessible to authorized users when needed.	Disruption of access or use	Redundancy, backups, load balancing, DoS protection, patching

10.1 Extensions to the triad

- **Authenticity**: being genuine and able to be verified and trusted, so that users and inputs are what they claim to be.
- **Accountability**: actions of an entity can be traced uniquely to it. This supports non-repudiation, deterrence and forensic analysis.

10.2 Mapping attacks to CIA

Interception breaks confidentiality, modification breaks integrity, interruption breaks availability, and fabrication breaks authenticity (and integrity).

11. Likely Exam Questions and Answer Outlines

1. **Distinguish between passive and active attacks.** Define both, list the two passive and four active types with one example each, give the comparison table in Section 4.3, and state that passive attacks are prevented while active attacks are detected and recovered from.
2. **Explain the OSI security architecture.** Define attack, service and mechanism, give the five service categories and the specific and pervasive mechanisms, and state how they relate.
3. **Explain security services.** Give the table in Section 5 and one line for each of the five categories.
4. **Explain the conventional encryption model with a diagram.** Draw source, encryption algorithm, key from a secure channel, ciphertext, opponent, decryption algorithm and destination. Write Y = E(K, X) and X = D(K, Y), the two requirements, and Kerckhoffs's principle.
5. **Explain the CIA triad.** Define each property, give a failure and a control for each, and mention authenticity and accountability.
6. **Write short notes on malicious code.** Give the table of types and the virus phases, then countermeasures.
7. **Differentiate between a threat, a vulnerability and an attack.** Use the table in Section 3.

Diagrams to practice

- Conventional encryption model (source, encryption, channel, opponent, decryption, destination, key distribution).

- Four threat categories: normal flow, interruption, interception, modification, fabrication.
- Passive attacks (eavesdropping) and active attacks (masquerade, replay, modification, DoS) showing the opponent's position.

Sources consulted

- ITU-T X.800 Security Architecture for OSI and RFC 4949 (Internet Security Glossary), as summarized in university lecture notes including Raj Jain, Washington University in St. Louis, Network Security overview and IARE Information Security lecture notes.
- Atul Kahate, Cryptography and Network Security, Tata McGraw Hill (course text).
- William Stallings, Cryptography and Network Security, for the threat categories, brute-force table and CIA extensions.